🧪 15 — Sensitive Data Exposure & Insecure Cryptography

Sensitive Data Exposure & Insecure Cryptography

OWASP: A02 - Cryptographic Failures | **CWE**: CWE-312, CWE-319 | **Severity**: 🟠 High

---

📖 Description

Sensitive data exposure occurs when applications fail to adequately protect sensitive information like passwords, credit card numbers, health records, etc. This includes transmitting data in cleartext, using weak crypto algorithms, or not encrypting data at rest.

🔍 Affected Endpoints

```
http://localhost/bWAPP/insecure_login_1.php   (Cleartext HTTP)
http://localhost/bWAPP/insecure_login_2.php   (Base64 'encoding')
http://localhost/bWAPP/insecure_login_3.php   (Hashed - MD5)
http://localhost/bWAPP/crypto_md5.php
http://localhost/bWAPP/crypto_base64.php
```

⚠️ Security Level: LOW

PoC — Cleartext Credentials in HTTP

```
# Login form submits over HTTP (not HTTPS)
# Capture with Wireshark:
# Filter: http.request.method == POST
# Follow TCP Stream
# See: login=admin&password=secret123 in plaintext

# Or use tcpdump:
sudo tcpdump -i lo -A 'tcp port 80 and (((ip[2:2] - ((ip[0]
&0xf)<<2)) - ((tcp[12]&0xf0)>>2)) != 0)'
```

PoC — Base64 "Encryption"

```
# Observe HTTP request headers:
# Authorization: Basic YWRtaW46c2VjcmV0

# Decode base64 (NOT encryption!):
echo 'YWRtaW46c2VjcmV0' | base64 -d
# Output: admin:secret

# Encode your own:
echo -n 'admin:newpass' | base64
```

PoC — MD5 Password Hashing (Weak)

```
# MD5 is cryptographically broken
# Crack with hashcat:
hashcat -m 0 md5_hash.txt /usr/share/wordlists/rockyou.txt

# Or use online cracking:
# https://crackstation.net
# https://hashes.com

# Common MD5 hashes:
# 5f4dcc3b5aa765d61d8327deb882cf99 = 'password'
# 21232f297a57a5a743894a0e4a801fc3 = 'admin'
```

PoC — Source Code Review

```
# Check if credentials stored in plaintext in source/confi
g:
grep -r 'password' /var/www/html/bWAPP/*.php
grep -r 'db_pass' /var/www/html/bWAPP/
cat /var/www/html/bWAPP/admin/settings.php
```

⚠️ Security Level: MEDIUM

Defense Applied

Passwords hashed with MD5 (still weak, rainbow tables exist).

Bypass

```
# Crack MD5 with hashcat
hashcat -m 0 -a 0 hash.txt rockyou.txt

# Use CrackStation (online, free)
# MD5 lookup tables contain billions of common passwords
```

⚠️ Security Level: HIGH

Defense Applied

- Passwords hashed with bcrypt (cost factor 12)
- HTTPS enforced for all transmission
- Sensitive data encrypted at rest

```
// Secure password hashing
$hash = password_hash($password, PASSWORD_BCRYPT, ['cost' =
> 12]);

// Verification
if (password_verify($input, $hash)) {
```

```
    // Login successful
}
```

📊 Common Crypto Weaknesses Found

Weakness	Why Vulnerable	Fix
MD5/SHA1	Broken, rainbow tables	Use bcrypt/Argon2
Base64	Not encryption, trivially decoded	Use AES-256
DES/3DES	Key too short, crackable	Use AES-256
ECB mode	Same input = same output	Use GCM mode
Hardcoded keys	In source code, easy to find	Use key management

✅ Remediation

1. **bcrypt/scrypt/Argon2** for password hashing
2. **TLS 1.2+** for all data in transit
3. **AES-256-GCM** for data at rest
4. **No hardcoded secrets** — use environment variables
5. **HSTS header**: Force HTTPS

```
// Password storage
$hash = password_hash($_POST['password'], PASSWORD_ARGON2I
D);

// HSTS
header('Strict-Transport-Security: max-age=31536000; includ
eSubDomains');
```

📚 References

- CWE-312: https://cwe.mitre.org/data/definitions/312.html
- OWASP Crypto: https://owasp.org/Top10/A02_2021-Cryptographic_Failures/